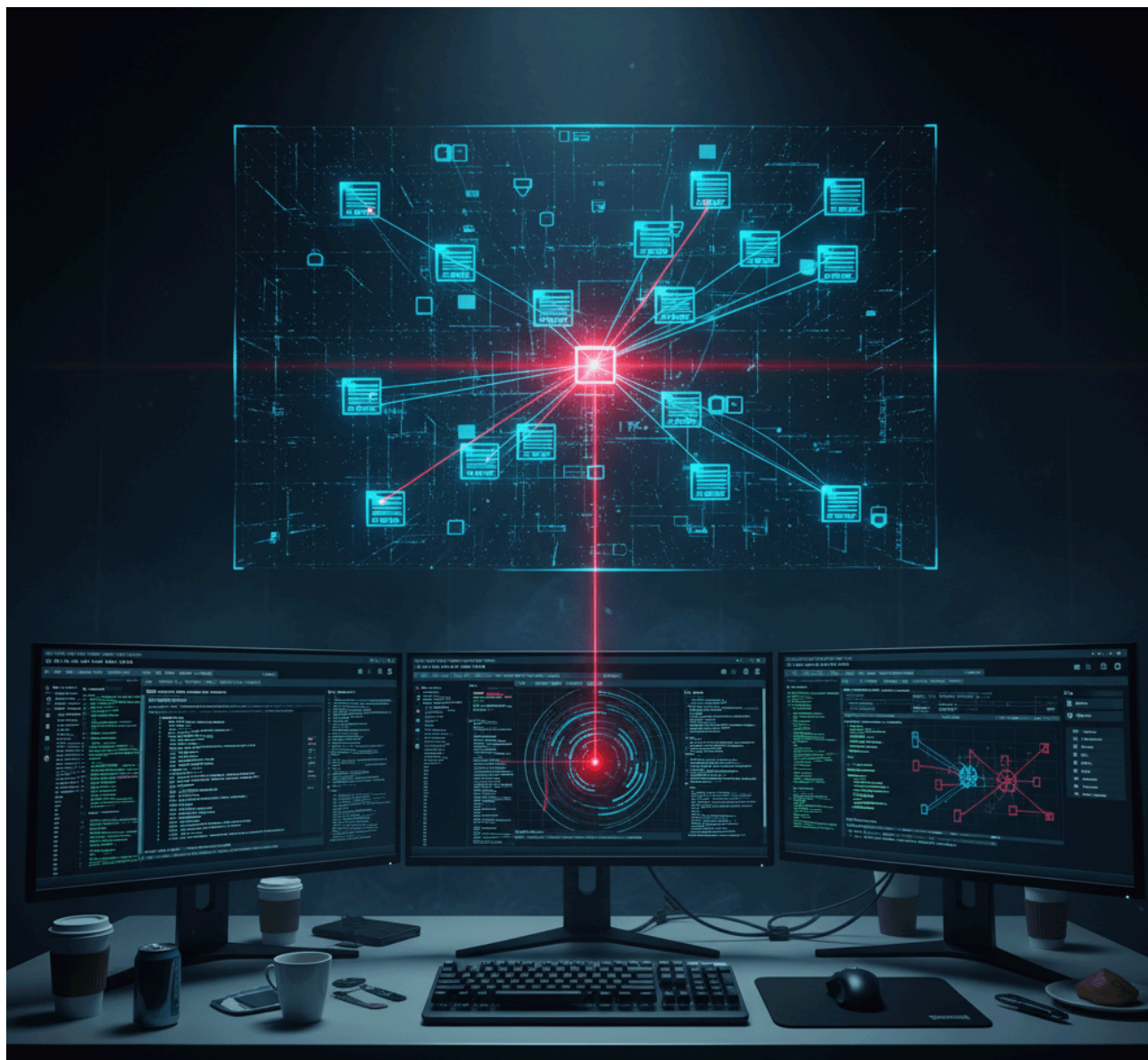


Создание пентест-стенда: ваша персональная лаборатория Active Directory с типовыми уязвимостями

 redsec.by/article/sozдание-pentest-stenda-vasha-personalnaya-laboratoriya-active-directory-s-tipovymi-uyazvimostyami

Red Teams | 23 октября 2025



Зачем нужна собственная лаборатория для пентеста Active Directory?

В мире, где более 90% компаний из списка Fortune 1000 используют Active Directory (AD) для управления своими IT-инфраструктурами, навыки тестирования на проникновение этой службы становятся не просто желательными, а критически важными. Теоретические знания уязвимостей и техник атак бесполезны без практического применения. Практические навыки пентеста Active Directory

невозможно развить без реальной среды для отработки техник атак. Создание собственной уязвимой лаборатории позволяет специалистам по информационной безопасности и энтузиастам безопасно и легально изучать методы компрометации доменной инфраструктуры, не рискуя повредить производственные системы. Современные корпоративные сети на базе Windows Server и Active Directory содержат множество типовых уязвимостей и неправильных конфигураций, которые злоумышленники активно эксплуатируют для получения привилегированного доступа.

Эта статья, подготовленная при участии опытного эксперта по кибербезопасности, станет вашим исчерпывающим руководством по созданию, настройке и использованию собственной лаборатории для пентеста AD. Мы пройдем путь от проектирования архитектуры до реализации сложных атак и настройки средств мониторинга, делая материал понятным даже для начинающих специалистов.

Архитектура лабораторного стенда: от базы до продвинутого уровня

Проектирование архитектуры — первый и один из самых важных этапов. От правильности выбора компонентов и их конфигурации зависит, насколько реалистичные сценарии вы сможете отрабатывать.

Минимальная конфигурация

Для новичков, делающих первые шаги в пентесте AD, не требуется разворачивать сложную и ресурсоемкую инфраструктуру. Базовая лаборатория должна включать:

- **Контроллер домена (Domain Controller):** Сердце вашей сети. Используйте Windows Server 2019/2022 с установленными ролями Active Directory Domain Services (AD DS) и DNS. Evaluation-версии от Microsoft доступны бесплатно на 180 дней, чего более чем достаточно для обучения.
- **Рабочие станции:** 1-2 виртуальные машины под управлением Windows 10/11. Эти машины будут присоединены к вашему домену и будут имитировать компьютеры рядовых сотрудников.
- **Атакующая машина:** Ваш командный центр. Рекомендуется использовать дистрибутивы, специально "заточенные" под пентест, такие как Kali Linux или Parrot Security OS. Они поставляются с огромным набором предустановленных инструментов, что избавляет вас от необходимости их ручной установки и настройки.

Расширенная конфигурация

Когда базовые атаки станут для вас слишком простыми, лабораторию можно и нужно усложнять. Для отработки сложных сценариев, имитирующих крупные корпоративные сети, рекомендуется развернуть многодоменную инфраструктуру:

- **Несколько доменов в одном лесу:** Создайте конфигурацию с родительским и дочерним доменами (parent-child), чтобы изучать атаки, связанные с доверительными отношениями внутри одного леса.
- **Отдельный лес:** Разверните второй, независимый лес и настройте между ними доверительные отношения (trusts). Это откроет возможности для практики межлесных атак.
- **Дополнительные серверные роли:** Для максимального реализма добавьте серверы с типичными корпоративными службами:
 - **Certificate Authority (AD CS):** Центр сертификации — золотая жила для пентестера из-за частых ошибок в его конфигурации.
 - **Файловый сервер:** Для отработки атак на сетевые шары и перехвата учетных данных.
 - **SQL Server:** Позволит практиковать специфичные атаки на базы данных и связанные с ними векторы повышения привилегий.
- **Разнообразие рабочих станций:** Увеличьте количество клиентских машин до 3-5 и создайте различные группы пользователей с разными уровнями доступа.

Системные требования

Виртуализация — процесс ресурсоемкий. Убедитесь, что ваш хостовый компьютер справится с нагрузкой:

- **ОЗУ:** Минимум 16 ГБ для базовой конфигурации. Если вы планируете использовать готовые решения вроде GOAD, рекомендуется иметь 32 ГБ и более.
- **Процессор:** Современный Intel Core i7 или его аналог от AMD с поддержкой технологий виртуализации (VT-x/AMD-V).
- **Дисковое пространство:** Быстрый SSD-накопитель — залог комфортной работы. Для базовой лаборатории потребуется 100-150 ГБ, для расширенной — от 200 ГБ.
- **Гипервизор:** Выбор зависит от ваших предпочтений и операционной системы. Популярные варианты включают VirtualBox (бесплатный и кроссплатформенный), VMware Workstation, Hyper-V (встроен в Windows Pro/Enterprise) или Proxmox (для развертывания на отдельном сервере).

Варианты развертывания лаборатории: ручной труд против автоматизации

Создать лабораторию можно двумя путями: вручную настраивая каждый компонент или используя скрипты и фреймворки для автоматизации.

Ручная установка

Традиционный подход, который отлично подходит для глубокого понимания всех процессов. Он предполагает пошаговую настройку каждого элемента:

- **Установка ОС:** Установите Windows Server 2019/2022 из загруженного evaluation ISO-образа.
- **Повышение роли:** Используя Server Manager, повысьте сервер до роли контроллера домена, создав новый лес и домен.
- **Создание структуры AD:** С помощью консоли "Active Directory Users and Computers" создайте организационные единицы (OU), группы безопасности и учетные записи пользователей.
- **Присоединение к домену:** Установите клиентские ОС (Windows 10/11) и присоедините их к созданному домену.
- **Внедрение уязвимостей:** Самый творческий этап. Вручную создайте неправильные конфигурации и уязвимости, которые мы подробно рассмотрим ниже.

Автоматизированное развертывание

Современные инструменты позволяют развернуть сложную лабораторию за считанные минуты или часы, а не дни. Это идеальный вариант, если вы хотите сосредоточиться непосредственно на пентесте.

- **AutomatedLab:** Мощный PowerShell-модуль, который позволяет описать всю инфраструктуру в виде скрипта и автоматически развернуть ее на Hyper-V или в облаке Azure. Идеально для тех, кто предпочитает экосистему Microsoft.
- **BadBlood:** Инструмент, предназначенный не для создания инфраструктуры, а для ее наполнения. Он заполняет существующий домен огромным количеством пользователей, групп, компьютеров и сложными, запутанными правами доступа (ACL), создавая реалистичный "шум", как в настоящих корпоративных сетях.

- **GOAD (Game of Active Directory):** Пожалуй, самое популярное готовое решение. GOAD использует Vagrant/Terraform и Ansible для автоматического развертывания целой инфраструктуры с предустановленными уязвимостями.
 - **Преимущества GOAD:**
 - **Несколько конфигураций:** От базовой MINILAB (2 ВМ) до полной GOAD (5 ВМ, 2 леса, 3 домена) и специализированной SCCM.
 - **Кроссплатформенность:** Поддерживает VirtualBox, VMware, Proxmox и даже облачные провайдеры.
 - **Готовые уязвимости:** Содержит десятки типовых неправильных конфигураций, готовых для эксплуатации.
 - **Развертывание GOAD:** Процесс установки максимально упрощен. После клонирования репозитория с GitHub и установки зависимостей, лаборатория разворачивается одной командой: `./goad.sh -t install -l GOAD -p virtualbox -m local`.

Создание уязвимостей в лаборатории: поле для экспериментов

Теперь перейдем к самой интересной части — намеренному "заражению" нашей лаборатории типовыми уязвимостями. Именно они станут целями для ваших атак.

1. Слабые пароли и политики

Самая распространенная и простая в эксплуатации уязвимость.

- **Настройка:** Через групповые политики (Group Policy) отключите требования к сложности паролей, установите минимальную длину в 4-6 символов.
- **Реализация:** Создайте пользователей с очевидными паролями: Password123, Summer2025!, Welcome1. Также можно настроить Fine-Grained Password Policy, чтобы разные группы пользователей имели разные (в том числе и слабые) парольные политики.

2. Kerberoasting

Атака, направленная на получение хешей паролей сервисных учетных записей.

- **Настройка:** Создайте обычную учетную запись пользователя, а затем привяжите к ней имя службы (Service Principal Name, SPN).

```
# Создание пользователя службы
New-ADUser -Name "SQLService" -AccountPassword (ConvertTo-SecureString "MyWeakPa
# Установка SPN
setspn -a MSSQLSvc/sql01.domain.local:1433 domain\SQLService
```

- **Механизм атаки:** Любой пользователь домена может запросить у Kerberos билет (TGS) для этой службы. Этот билет зашифрован хешем пароля сервисной учетной записи. Атакующий перехватывает билет и пытается подобрать пароль в офлайн-режиме, не взаимодействуя с контроллером домена.

3. AS-REP Roasting

Еще одна офлайн-атака на пароли, но на этот раз — на обычных пользователей.

- **Настройка:** В свойствах учетной записи пользователя (вкладка "Account") установите флаг "Do not require Kerberos preauthentication".
- **Механизм атаки:** Эта опция позволяет злоумышленнику запросить часть аутентификационных данных пользователя без предварительной аутентификации. Эти данные зашифрованы паролем пользователя, что снова позволяет проводить офлайн-брутфорс.

4. Неправильные ACL (Access Control Lists)

Избыточные права доступа — прямой путь к повышению привилегий.

- **Настройка:** Предоставьте низкопривилегированному пользователю опасные права на высокопривилегированные объекты (например, на группу "Domain Admins").
 - GenericAll: Полный контроль.
 - GenericWrite: Право на изменение любых атрибутов.
 - WriteDACL: Право на изменение прав доступа к объекту.
 - WriteOwner: Право сменить владельца объекта.
 - ForceChangePassword: Право сменить пароль пользователя, не зная текущего.
- **Пример создания уязвимости через PowerShell:**

```
$user = Get-ADUser -Identity "lowprivuser"
$targetGroup = Get-ADGroup -Identity "Domain Admins"
$acl = Get-Acl "AD:\$(($targetGroup.DistinguishedName))"
$sid = New-Object System.Security.Principal.SecurityIdentifier $user.SID
$ace = New-Object System.DirectoryServices.ActiveDirectoryAccessRule(
    $sid,
    [System.DirectoryServices.ActiveDirectoryRights]::GenericWrite,
    [System.Security.AccessControl.AccessControlType]::Allow
)
$acl.AddAccessRule($ace)
Set-Acl -Path "AD:\$(($targetGroup.DistinguishedName))" -AclObject $acl
```

5. Пароли в GPP (Group Policy Preferences)

Устаревшая, но все еще встречающаяся уязвимость.

Настройка: Создайте групповую политику, которая, например, создает локального администратора с заданным паролем. До патча MS14-025 пароль хранился в XML-файле в папке SYSVOL, зашифрованный с помощью публично известного AES-ключа. Вы можете симитировать это поведение для образовательных целей.

6. Неограниченное делегирование (Unconstrained Delegation)

Крайне опасная конфигурация, позволяющая серверу имперсонировать любого пользователя.

- **Настройка:** В свойствах учетной записи компьютера установите опцию "Trust this computer for delegation to any service (Kerberos only)".
- **Механизм атаки:** Когда пользователь (например, администратор домена) подключается к такому серверу, его TGT-билет Kerberos сохраняется в памяти сервера. Скомпрометировав сервер, атакующий может извлечь этот билет и использовать его для доступа к любым другим ресурсам от имени администратора.

7. Уязвимости AD CS (Active Directory Certificate Services)

Неправильно настроенный центр сертификации — это открытая дверь в домен.

- **ESC1:** Создайте шаблон сертификата, который позволяет запрашивающей стороне указывать альтернативное имя субъекта (Subject Alternative Name - SAN). Это позволит обычному пользователю запросить сертификат от имени администратора домена.
- **ESC8:** Включите роль Web Enrollment и настройте автоматическую выдачу сертификатов. Это открывает вектор для NTLM relay атак на веб-интерфейс центра сертификации.

8. Критические CVE

Для максимального реализма оставьте некоторые системы не обновленными, чтобы отработать эксплуатацию известных уязвимостей. **Важно: это можно делать только в полностью изолированной среде!**

- **Zerologon (CVE-2020-1472):** Позволяет сбросить пароль компьютерной учетной записи контроллера домена.
- **PrintNightmare (CVE-2021-34527):** Удаленное выполнение кода через службу диспетчера печати.
- **PetitPotam (CVE-2021-36942):** Принуждает сервер аутентифицироваться на машине атакующего, что используется для NTLM relay.

Инструменты для атак на лабораторию: арсенал пентестера

Ваша лаборатория готова. Теперь время вооружиться. Арсенал современного пентестера огромен и разнообразен.

Разведка и перечисление

Первый шаг любой атаки — сбор информации.

- **BloodHound/SharpHound:** Графически визуализирует связи и пути атак в AD. Незаменимый инструмент для поиска путей повышения привилегий.
- **PowerView:** PowerShell-модуль для детального перечисления практически любых объектов и настроек в домене.
- **CrackMapExec/NetExec:** Швейцарский нож для пентеста Windows-сетей. Позволяет проводить сканирование, брутфорс, выполнение команд и многое другое.
- **enum4linux-ng:** Утилита для сбора информации через SMB и RPC.

Получение учетных данных

Цель этого этапа — завладеть паролями, хешами или билетами Kerberos.

- **Responder:** Перехватывает NTLM-хешы, отравляя трафик LLMNR/NBT-NS.
- **Mimikatz:** Легендарный инструмент для извлечения паролей и хешей из памяти процесса LSASS, а также для проведения атак Golden/Silver Ticket.
- **Rubeus:** Мощный инструмент для работы с билетами Kerberos, проведения атак Kerberoasting и AS-REP Roasting.
- **Impacket:** Набор Python-скриптов для работы с сетевыми протоколами Windows. Включает:
 - `secretsdump.py`: Для дампа хешей из SAM, NTDS.dit и LSA Secrets.
 - `GetNPUsers.py`: Для AS-REP Roasting.
 - `GetUserSPNs.py`: Для Kerberoasting.
 - `ntlmrelayx.py`: Для проведения NTLM relay атак.

Эксплуатация и повышение привилегий

Используя полученные данные и найденные уязвимости, переходим к захвату контроля.

- **Certipy:** Инструмент для автоматизации эксплуатации уязвимостей AD CS (ESC1-ESC8).
- **Coercer/PetitPotam:** Утилиты для принудительной аутентификации серверов, используемой в NTLM relay атаках.
- **ZeroLogon exploit:** Скрипты для эксплуатации CVE-2020-1472.

Post-exploitation (Действия после компрометации)

Получив права администратора домена, атакующий закрепляется в системе.

- **DCSync:** Атака, при которой машина атакующего, используя права администратора, маскируется под контроллер домена и запрашивает репликацию всех хешей паролей из AD.
- **Golden Ticket:** Создание поддельного TGT-билета с использованием хеша учетной записи krbtgt. Дает неограниченный и долговременный доступ ко всему домену.
- **Silver Ticket:** Создание поддельного TGS-билета для доступа к определенной службе.

Мониторинг и детектирование атак: взгляд защитника

Полноценное обучение включает не только навыки атаки, но и понимание, как эти атаки обнаруживать. Настройка мониторинга превратит вашу лабораторию в настоящий киберполигон.

Sysmon

System Monitor (Sysmon) — это драйвер и служба Windows, которая предоставляет детализированное логирование системной активности.

- **Установка:** `sysmon64.exe -accepteula -i sysmonconfig.xml`
- **Конфигурация:** Используйте готовые продвинутые конфигурации, такие как SwiftOnSecurity или Olaf Hartong, чтобы собирать только наиболее релевантные для ИБ-специалиста события.

ELK Stack / HELK

Для централизованного сбора и анализа логов разверните стек ELK (Elasticsearch, Logstash, Kibana). Для упрощения можно использовать готовый проект **HELK (Hunting ELK)**, который поставляется с предустановленными дашбордами и правилами для анализа атак на AD.

Настройка аудита Active Directory

Включите расширенный аудит на контроллерах домена через групповые политики. Отслеживайте события входа, управления учетными записями, доступа к объектам каталога и изменения политик.

Windows Event Forwarding (WEF)

Настройте централизованный сбор логов с рабочих станций и серверов на один сервер-коллектор. Это позволит анализировать события со всей инфраструктуры в

одном месте.

Best Practices при Работе с Лабораторией

- **Изоляция сети:** Лаборатория должна быть полностью изолирована от вашей основной домашней или рабочей сети. Используйте режим "Internal Network" или "Host-Only" в вашем гипервизоре.
- **Создание снапшотов:** Перед проведением потенциально деструктивной атаки всегда делайте снимок состояния (snapshot) виртуальных машин. Это позволит мгновенно откатиться к чистому состоянию.
- **Документирование:** Ведите подробную документацию: карта сети, список учетных записей и паролей, перечень внедренных уязвимостей и предполагаемые пути их эксплуатации.
- **Обновление и расширение:** Кибербезопасность не стоит на месте. Периодически добавляйте в лабораторию новые уязвимости, интегрируйте средства защиты (EDR, SIEM) и усложняйте архитектуру.

Дополнительные сценарии и расширения

Интеграция Azure AD (Entra ID)

Современные сети часто являются гибридными. Настройте синхронизацию вашей локальной AD с Azure AD (теперь Entra ID) с помощью Azure AD Connect. Это позволит практиковать атаки на гибридные среды, PTA (Pass-Through Authentication) и PHS (Password Hash Synchronization).

Тестирование средств защиты (EDR)

Разверните в лаборатории EDR-решение (Endpoint Detection and Response) и отрабатывайте техники его обхода:

- **Обфускация:** Маскировка вредоносного кода.
- **Living off the Land (LotL):** Использование легитимных системных утилит Windows для атакующих действий.
- **Прямые системные вызовы (Direct System Calls):** Обход хуков EDR в пользовательском режиме.

Использование в обучении и для сертификаций

Наличие собственной лаборатории — неоценимое преимущество при подготовке к ведущим отраслевым сертификациям, таким как:

- OSCP (Offensive Security Certified Professional)
- CRTE (Certified Red Team Expert)

- CRTP (Certified Red Team Professional)
- PNPT (Practical Network Penetration Tester)

Создание собственной лаборатории Active Directory с типовыми уязвимостями — это не просто рекомендация, а фундаментальная необходимость для любого специалиста по информационной безопасности, стремящегося к профессиональному росту. Современные инструменты автоматизации, такие как GOAD, AutomatedLab и BadBlood, демократизировали этот процесс, сделав его доступным для каждого.

Правильно сконфигурированный стенд, включающий не только уязвимости, но и средства мониторинга, позволяет сформировать целостное видение: понимать не только как провести атаку, но и какие "следы" она оставляет. Это знание критически важно как для атакующей стороны (Red Team), так и для защищающейся (Blue Team).

Помните, что все полученные знания и навыки должны применяться исключительно в легальных и этических целях. Ваша лаборатория — это ваш личный киберполигон, безопасное пространство для экспериментов, ошибок и, в конечном итоге, для становления высококлассным профессионалом в области кибербезопасности.